

RAPPORT D'ÉVALUATION TECHNIQUE & SÉCURITÉ MATÉRIELLE

Banc d'essai d'instrumentation & rétro-ingénierie de bus de communication

Évaluation de la Sécurité des Bus Inter-Composants

Sniffing Passif I²C, Rétro-Ingénierie de Mémoire EEPROM 24LC256
et Contre-Mesures Matérielles

Piaw CAVAREC

Spécialité : Audit Hardware · Sécurité des Systèmes Embarqués · Rétro-Ingénierie

Portfolio : piaw-cavarec.github.io

GitHub : github.com/piaw-cavarec

LinkedIn : linkedin.com/in/piaw-cavarec

Laboratoire Personnel de Recherche & Montée en Compétences Matérielles

Piaw CAVAREC · Septembre 2026

Table des matières

1	Fiche de Synthèse & Métadonnées du Projet	2
2	Résumé Exécutif (Executive Summary)	2
3	Modèle de Menace (Threat Model) & Cadre d'Évaluation	2
3.1	Le Risque du Périmètre Matériel Illusoire	2
3.2	Classification de l'Attaque Métrique CVSS v3.1	3
4	Fondamentaux Électriques & Architecture du Bus I²C	3
4.1	Topologie à Collecteur Ouvert (Open-Drain) & ET-Câblé	3
4.2	Dimensionnement des Résistances de Tirage (R_p)	4
4.3	Chronogrammes & Machine à États I ² C	4
5	Cible Matérielle : EEPROM Microchip 24LC256	4
5.1	Identification Physique du Boîtier	4
5.2	Brochage & Espace d'Adressage	5
5.3	Cycle Temporel d'Écriture Non-Volatile (t_{WR})	5
6	Banc d'Essai, Instrumentation & Méthodologie d'Acquisition	5
6.1	Méthodologie de Câblage & Contrôles Préalables	5
6.2	Dimensionnement Échantillonnage de Nyquist-Shannon	6
6.3	Stratégie de Déclenchement (Trigger Logic) & Gestion de Mémoire	6
7	Implémentation du Scénario d'Épreuve (ESP32-S3 / C++)	6
8	Décodage Protocolaire Multi-Niveaux & Exfiltration de Données	8
8.1	Déploiement des Décodeurs Empilés dans PulseView	8
8.2	Chronométrie Détaillée des Trames Interceptées	8
8.2.1	Trame d'Écriture Initiale (Phase d'Amorçage)	8
8.2.2	Trame de Lecture Cyclique (Phase Opérationnelle)	9
8.3	Extraction de la Charge Utile & Rétro-Ingénierie ASCII	9
9	Matrice des Risques & Analyse d'Impact Industriel	9
10	Contre-Mesures & Architecture Matérielle Sécurisée ("Zero Trust on PCB")	9
10.1	Niveau 1 : Remplacement par un Composant Sécurisé (Secure Element)	10
10.2	Niveau 2 : Chiffrement Applicatif de la Charge Utile (AEAD)	10
10.3	Niveau 3 : Règles de Routage & Durcissement du Circuit Imprimé	11
10.4	Niveau 4 : Verrouillage Matériel d'Écriture (Broche WP)	11
11	Conclusion & Bilan des Compétences	11
11.1	Compétences Techniques Valorisées	11
12	Références Techniques & Normatives	11
ANNEXES TECHNIQUES : CAHIER VISUEL & CAPTURES DE BANC		13
Annexe A	Architecture du Système & Modélisation Protocolaire	13
Annexe B	Galerie Photographique du Banc de Test Matériel	15
Annexe C	Captures d'Instrumentation & Preuves d'Exfiltration (PulseView)	17

1. Fiche de Synthèse & Métadonnées du Projet

Ce rapport technique détaille la caractérisation électrique, l’interception passive et l’extraction de données sensibles circulant sur un bus inter-composants au niveau circuit imprimé (*PCB*). Il formalise les résultats expérimentaux obtenus sur banc d’essai et propose un cadre d’ingénierie préventive pour les systèmes embarqués industriels et IoT.

Paramètre	Spécification / Description
Cible d’Évaluation	Mémoire EEPROM série I ² C Microchip 24LC256 (Boîtier PDIP-8)
Composant Hôte (Maître)	Espressif ESP32-S3 (Xtensa 32-bit Dual-Core @ 240 MHz, DevKitC-1)
Protocole Analysé	I ² C (<i>Inter-Integrated Circuit</i>) en mode Standard (100 kHz)
Instrumentation Matérielle	Analyseur logique USB 8 canaux 24 MHz (driver open-source <code>fx2lafw</code>)
Environnement Logiciel	Suite Sigrok / PulseView, Framework PlatformIO sous VS Code (C++)
Nature de l’Attaque	Écoute passive de bus sur carte (<i>On-board Bus Sniffing</i>), physique, non-invasive
Classification CVSS v3.1	6.8 (Gravité Moyenne / Impact critique sur la confidentialité en contexte IoT)
Vecteur CVSS v3.1	CVSS:3.1/AV:P/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

TABLE 1 – Fiche technique de synthèse du banc d’essai.

2. Résumé Exécutif (Executive Summary)

RÉSUMÉ EXÉCUTIF & CONSTAT DE SÉCURITÉ

Dans la conception des équipements électroniques connectés (IoT grand public, passerelles industrielles SCADA, dispositifs médicaux portables, unités télématiques automobiles), les contraintes d’espace mémoire interne sur le microcontrôleur principal conduisent fréquemment à déporter des informations critiques (clés cryptographiques, certificats d’authentification réseau, jetons de session, compteurs d’usage) sur des mémoires non-volatiles externes (EEPROM, Flash SPI).

Un biais de conception prédominant, désigné sous le terme de **Perimeter Defense Fallacy**, postule implicitement que le boîtier mécanique externe de l’appareil suffit à garantir l’inviolabilité des bus de communication circulant sur le circuit imprimé.

Résultat de l’évaluation : À l’aide d’un banc d’instrumentation à faible coût ($\approx 25\text{ €}$), l’intégralité du trafic échangé entre le microcontrôleur hôte et la mémoire externe a été capturé passivement et décodé sans laisser aucune trace physique ni perturber le fonctionnement opérationnel du système. La clé d’authentification simulée (`SECRET_KEY_1234`) a été exfiltrée en clair dès sa première transaction, démontrant une rupture totale de confidentialité.

Schéma du vecteur d’attaque : L’architecture complète d’interception passive sur le bus physique est synthétisée sur la [Figure 1](#) (*voir Annexe A, p. 13*).

3. Modèle de Menace (Threat Model) & Cadre d’Évaluation

3.1. Le Risque du Périmètre Matériel Illusoire

Dans une architecture de sécurité en profondeur, aucun sous-système ne devrait faire aveuglément confiance au support physique qui le relie à ses périphériques. Dès lors qu’un appareil connecté est déployé en milieu non maîtrisé, il est exposé à trois scénarios majeurs :

1. **Evil Maid Attack (Attaque par accès physique temporaire)** : Un individu malveillant dispose d'un accès physique temporaire et furtif à l'équipement (ex. dans une chambre d'hôtel, un local technique non verrouillé ou un véhicule). Il ouvre le boîtier sans destruction, applique des micro-pointes de test sur les broches de l'EEPROM, enregistre les transactions lors de la phase d'amorçage, puis referme le boîtier.
2. **Interception sur la chaîne logistique (Supply Chain Interdiction)** : Modification ou pose d'un implant matériel miniature (ex. module d'écoute passif ultra-compact) sur le PCB entre l'usine d'assemblage et la livraison finale.
3. **Rétro-ingénierie post-saisie ou vol** : Analyse approfondie d'un équipement capturé afin d'extraire des identifiants globaux de flotte pour cloner des appareils sur le réseau de production.

3.2. Classification de l'Attaque Métrique CVSS v3.1

L'écoute passive sur bus de communication se classe dans la catégorie des **attaques physiques non-invasives** :

- Elle ne requiert aucune altération destructive du silicium (contrairement aux attaques invasives par décapage à l'acide ou micro-faisceau ionique FIB).
- Elle n'émet aucun signal parasite susceptible de perturber la communication nominale (les sondes de l'analyseur logique présentent une impédance d'entrée de $1\text{ M}\Omega \parallel 10\text{ pF}$, rendant leur présence virtuellement indétectable par le microcontrôleur hôte).

NOTATION DE VULNÉRABILITÉ CVSS v3.1

Score de Base CVSS v3.1 : 6.8 (Gravité Moyenne / Impact Élevé)

Vecteur complet : CVSS:3.1/AV:P/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

- **Attack Vector (AV :P)** : *Physical*. L'attaquant doit établir un contact électrique direct avec les pistes ou broches du bus sur le circuit imprimé.
- **Attack Complexity (AC :L)** : *Low*. Aucun contournement algorithmique complexe n'est requis en l'absence de chiffrement.
- **Privileges Required (PR :N)** : *None*. Aucun privilège préalable sur l'OS ou le firmware.
- **User Interaction (UI :N)** : *None*. L'attaque opère en totale autonomie dès la mise sous tension.
- **Scope (S :U)** : *Unchanged*. L'autorité de sécurité compromise est restreinte au composant.
- **Confidentiality (C :H)** : *High*. Compromission totale et irréversible des secrets transitant sur le bus.
- **Integrity (I :H)** : *High*. L'absence d'authentification mutuelle permettrait à un attaquant actif d'écraser la mémoire par injection de trames.
- **Availability (A :N)** : *None*. L'écoute passive ne dégrade pas la disponibilité nominale.

4. Fondamentaux Électriques & Architecture du Bus I²C

Une instrumentation rigoureuse impose la compréhension intime de la couche physique et des spécifications temporelles du protocole I²C (norme NXP UM10204).

4.1. Topologie à Collecteur Ouvert (Open-Drain) & ET-Câblé

Le bus I²C est un bus série synchrone semi-duplex à deux conducteurs :

- **SDA (Serial Data)** : Ligne de données bidirectionnelle.
- **SCL (Serial Clock)** : Ligne d'horloge cadencée par le maître.

Chaque équipement raccordé au bus possède des étages de sortie en **drain ouvert** (*Open-Drain*). Le composant ne peut forcer activement la ligne qu'au niveau logique bas (0 V) en saturant un transistor

NMOS interne relié à la masse (V_{SS}). Le retour à l'état logique haut ($V_{DD} = 3.3 \text{ V}$) est assuré passivement par une résistance de rappel (*pull-up resistor*, notée R_p).

Cette disposition réalise une fonction logique **ET-câblé** (*Wired-AND*) : la ligne est au repos à l'état haut (1). Dès qu'un composant active son transistor, la ligne commute à l'état bas (0). Ce principe élimine tout risque de court-circuit en cas de contention de bus et autorise l'arbitrage multi-maître ainsi que le mécanisme d'étirement d'horloge (*Clock Stretching*) par l'esclave.

4.2. Dimensionnement des Résistances de Tirage (R_p)

Le dimensionnement de R_p obéit à deux contraintes physiques contradictoires :

1. **Borne inférieure** ($R_{p,\min}$) : Conditionnée par le courant d'évacuation maximal ($I_{OL} = 3 \text{ mA}$) admissible par le transistor NMOS pour garantir une tension de niveau bas $V_{OL} \leq 0.4 \text{ V}$:

$$R_{p,\min} = \frac{V_{DD} - V_{OL}}{I_{OL}} = \frac{3.3 \text{ V} - 0.4 \text{ V}}{3 \times 10^{-3} \text{ A}} \approx 966 \Omega \quad (1)$$

2. **Borne supérieure** ($R_{p,\max}$) : Limitée par la constante de temps du circuit RC formé par R_p et la capacité parasite cumulée du bus (C_b). Pour le mode Standard (100 kHz), le temps de montée maximal autorisé est $t_r \leq 1000 \text{ ns}$:

$$t_r \approx 0.8473 \cdot R_p \cdot C_b \implies R_{p,\max} = \frac{t_r}{0.8473 \cdot C_b} \quad (2)$$

Pour une plaque d'essai avec une capacité parasite estimée à $C_b \approx 50 \text{ pF}$ (capacités de broches, fils Dupont et colonnes métalliques de la breadboard) :

$$R_{p,\max} = \frac{1000 \times 10^{-9}}{0.8473 \times 50 \times 10^{-12}} \approx 23.6 \text{ k}\Omega \quad (3)$$

Sur notre banc, des valeurs de tirage de $2.2 \text{ k}\Omega$ à $4.7 \text{ k}\Omega$ assurent des fronts montants francs et une immunité satisfaisante au bruit.

4.3. Chronogrammes & Machine à États I²C

Le protocole I²C définit des règles strictes régissant les transitions d'état :

- **Stabilité des données** : L'état de SDA doit être rigoureusement stable pendant toute la durée où SCL est au niveau haut. Tout changement d'état de SDA lorsque SCL est à l'état haut constitue une condition de contrôle.
- **Condition START (S)** : Transition descendante de SDA pendant que SCL est au niveau haut. Elle réserve le bus.
- **Condition STOP (P)** : Transition montante de SDA pendant que SCL est au niveau haut. Elle libère le bus.
- **Acquittement (ACK / NACK)** : Chaque octet (8 bits) transmis est suivi d'un 9^e cycle d'horloge. L'émetteur relâche SDA ; le récepteur doit forcer SDA à 0 pour générer un **ACK**. Si SDA demeure à l'état haut (1), la trame est sanctionnée par un **NACK**.

5. Cible Matérielle : EEPROM Microchip 24LC256

5.1. Identification Physique du Boîtier

L'inspection optique du composant monté sur le banc (**Figure 4**, *Annexe B*, p. 15) révèle les marquages constructeur suivants gravés au laser :

[Logo Microchip] 24LC256 - I/P YU8 - 2601

L'analyse de la fiche technique (*Datasheet Microchip DS20001203*) fournit les éléments d'identification :

- **24LC256** : Référence commerciale désignant une EEPROM série I²C d'une capacité de 256 Kbits.
- **I** : Plage de température industrielle (−40°C à +85°C).
- **P** : Type de boîtier PDIP à 8 broches traversantes (*Plastic Dual In-line Package*).
- **YU8 / 2601** : Codes de traçabilité d'usine et date de fabrication (Semaine 01 de l'année 2026).

5.2. Brochage & Espace d'Adressage

Le boîtier PDIP-8 présente la configuration de broches résumée dans le Tableau 2 et illustrée sur la documentation constructeur (**Figure 5**, *Annexe B*, p. 15).

Broche	Nom	Fonction & Raccordement Expérimental
1, 2, 3	A0, A1, A2	Entrées de sélection matérielle d'adresse esclave. Reliées à la masse (GND) pour fixer l'adresse I ² C à 0x50.
4	Vss	Masse commune du système (GND , 0 V).
5	SDA	Ligne de données série I ² C, connectée au GPIO 4 de l'ESP32-S3.
6	SCL	Ligne d'horloge série I ² C, connectée au GPIO 5 de l'ESP32-S3.
7	WP	<i>Write Protect</i> . Reliée à GND pour autoriser l'écriture sur l'ensemble de la mémoire (si reliée à V_{CC} , l'écriture est inhibée).
8	Vcc	Alimentation positive (+3.3 V régulée issue de la carte ESP32-S3).

TABLE 2 – Configuration des broches de l'EEPROM 24LC256 sur le banc d'essai.

La capacité mémoire de 256 Kbits correspond à :

$$\frac{256 \times 1024 \text{ bits}}{8 \text{ bits/octet}} = 32\,768 \text{ octets (32 Ko)} \quad (4)$$

Pour adresser cet espace compris entre 0x0000 et 0x7FFF, la puce requiert un **adressage sur 16 bits**. Toute commande d'accès mémoire transmet :

1. L'octet de contrôle du périphérique (0xA0 pour l'écriture avec l'adresse 7-bit 0x50 et bit $R/\overline{W} = 0$).
2. L'octet de poids fort de l'adresse mémoire (**MSB** : *Most Significant Byte*).
3. L'octet de poids faible de l'adresse mémoire (**LSB** : *Least Significant Byte*).

5.3. Cycle Temporel d'Écriture Non-Volatile (t_{WR})

La programmation physique des cellules mémoires (piégeage d'électrons par injection Fowler-Nordheim via le générateur haute tension interne) impose un temps de cycle d'écriture :

$$t_{WR} \leq 5 \text{ ms} \quad (5)$$

Pendant cet intervalle de 5 ms, l'EEPROM désactive son interface I²C et renvoie un **NACK** systématique à toute tentative de communication. Le firmware du microcontrôleur doit donc obligatoirement marquer une temporisation logicielle (> 5 ms) ou procéder par scrutation d'acquiescement (*Acknowledge Polling*) avant d'émettre une transaction consécutive. Les spécifications limites de tolérance électrique et la tenue aux décharges électrostatiques sont récapitulées sur la **Figure 6** (*Annexe B*, p. 15).

6. Banc d'Essai, Instrumentation & Méthodologie d'Acquisition

6.1. Méthodologie de Câblage & Contrôles Préalables

Le banc a été assemblé en appliquant les règles strictes de laboratoire d'électronique :

- **Test de continuité électrique** : Vérification de chaque conducteur Dupont au multimètre en mode bip sonore pour prévenir les faux contacts liés aux connecteurs femelles usés.
- **Contrôle des rails d'alimentation** : Mesure de la tension continue aux bornes de la puce ($V_{CC} = 3.29$ V) et absence de court-circuit rail-to-rail.
- **Référence de masse unique** : Raccordement de la masse de l'analyseur logique USB directement au rail GND de la plaque d'essai afin d'éviter les boucles de masse et les décalages de potentiel de référence.

Le banc expérimental instrumenté associe le microcontrôleur ESP32-S3 (**Figure 7**), le module EEPROM (**Figure 8**) et l'analyseur logique connecté en dérivation (**Figure 9**) (*voir galerie photographique en Annexe B, p. 16*).

6.2. Dimensionnement Échantillonnage de Nyquist-Shannon

L'analyseur logique USB utilisé embarque un contrôleur Cypress FX2LP fonctionnant sous le firmware libre `fx2lafw` (**Figure 10**). L'assignation des canaux physiques et la définition de la fréquence d'échantillonnage sont configurées directement dans PulseView (**Figure 11**) (*voir Annexe C, p. 17*).

D'après le **théorème d'échantillonnage de Nyquist-Shannon**, la fréquence d'échantillonnage f_e doit vérifier $f_e > 2 \cdot f_{\max}$. En métrologie numérique, la restitution fidèle d'un front logique nécessite d'échantillonner à une fréquence au moins 10 à 20 fois supérieure à la fréquence du signal carré :

- Fréquence d'horloge du bus : $f_{bus} = 100$ kHz (Période $T_{SCL} = 10$ μ s).
- Fréquence d'échantillonnage configurée : $f_e = 2$ MHz (Résolution temporelle $\Delta t = 500$ ns).
- Facteur de suréchantillonnage :

$$\text{Ratio} = \frac{2\,000\,000\text{ Hz}}{100\,000\text{ Hz}} = 20\times \quad (6)$$

Chaque bit I²C est ainsi mesuré sur 20 échantillons consécutifs, garantissant l'absence totale de repliement spectral (*aliasing*) et une distinction parfaite des temps d'établissement (*Setup Time*) et de maintien (*Hold Time*).

6.3. Stratégie de Déclenchement (Trigger Logic) & Gestion de Mémoire

La mémoire tampon de l'analyseur logique a été fixée à **1 million d'échantillons (1 MSamples)**. À un débit de 2 MHz, la durée maximale d'enregistrement continu est de :

$$T_{\text{fenêtre}} = \frac{10^6 \text{ échantillons}}{2 \times 10^6 \text{ échantillons/s}} = 0.5 \text{ s (500 ms)} \quad (7)$$

Problématique de Synchronisation Temporelle

L'ESP32-S3 requiert environ 1.5 seconde après mise sous tension pour exécuter le chargeur d'amorçage interne (*ROM bootloader*), initialiser ses horloges PLL et démarrer l'application PlatformIO. Si l'enregistrement démarrait sans condition, le tampon de 500 ms serait saturé de niveaux logiques hauts inactifs avant même que la première trame I²C ne soit émise.

Solution mise en œuvre : Configuration d'un **déclencheur matériel (Trigger) sur front descendant sur le canal SDA** (**Figure 12**, *voir Annexe C, p. 18*). Puisque les lignes sont maintenues à 3.3 V par les résistances de tirage, la première transition descendante sur SDA avec SCL au repos signe exclusivement la **condition START** de la transaction initiale d'écriture. L'analyseur conserve ses échantillons en mémoire circulaire et fige la capture précisément au début de la transmission utile.

7. Implémentation du Scénario d'Épreuve (ESP32-S3 / C++)

Le micrologiciel développé pour le microcontrôleur ESP32-S3 simule le fonctionnement classique d'un nœud IoT industriel : il stocke une clé d'authentification secrète ("`SECRET_KEY_1234`") dans

l'EEPROM externe à l'adresse 0x0010, puis la relit périodiquement toutes les deux secondes pour émuler une validation de jeton de session.

```
1  #include <Arduino.h>
2  #include <Wire.h>
3
4  #define I2C_SDA 4
5  #define I2C_SCL 5
6  #define EEPROM_ADDR 0x50  // A0=GND, A1=GND, A2=GND
7
8  const uint16_t MEM_ADDR = 0x0010;
9  const char PAYLOAD[] = "SECRET_KEY_1234";
10
11 // Ecriture d'une chaine de caracteres a une adresse memoire sur 16 bits
12 void writeEEPROM(uint16_t memAddress, const char* data) {
13     Wire.beginTransmission(EEPROM_ADDR);
14
15     // Transmission de l'adresse memoire sur 16 bits (MSB puis LSB)
16     Wire.write((uint8_t)(memAddress >> 8));  // Adresse haute
17     Wire.write((uint8_t)(memAddress & 0xFF)); // Adresse basse
18
19     for (int i = 0; data[i] != '\0'; i++) {
20         Wire.write((uint8_t)data[i]);
21     }
22     Wire.endTransmission();
23
24     // Attente imperative du cycle interne de programmation (max 5 ms)
25     delay(10);
26 }
27
28 // Lecture sequentielle d'octets depuis une adresse memoire
29 void readEEPROM(uint16_t memAddress, uint8_t length) {
30     // 1. Phase de positionnement du pointeur interne (Dummy Write)
31     Wire.beginTransmission(EEPROM_ADDR);
32     Wire.write((uint8_t)(memAddress >> 8));
33     Wire.write((uint8_t)(memAddress & 0xFF));
34     Wire.endTransmission();
35
36     // 2. Phase de requete de lecture
37     Wire.requestFrom((uint8_t)EEPROM_ADDR, length);
38     Serial.print("[Lecture I2C] : ");
39     while (Wire.available()) {
40         char c = Wire.read();
41         Serial.print(c);
42     }
43     Serial.println();
44 }
45
46 void setup() {
47     Serial.begin(115200);
48     Wire.begin(I2C_SDA, I2C_SCL);
49     Wire.setClock(100000); // Frequence fixee a 100 kHz (Standard-mode)
50
51     delay(1000);
52     Serial.println("\n--- Initialisation ecriture EEPROM ---");
53     writeEEPROM(MEM_ADDR, PAYLOAD);
54     Serial.println("Ecriture terminee.");
55 }
56
57 void loop() {
58     readEEPROM(MEM_ADDR, strlen(PAYLOAD));
59     delay(2000);
60 }
```

Listing 1 – Firmware d’écriture et de relecture cyclique sur l’EEPROM 24LC256 (PlatformIO / C++).

8. Décodage Protocolaire Multi-Niveaux & Exfiltration de Données

8.1. Déploiement des Décodeurs Empilés dans PulseView

L’architecture de décodage de PulseView s’appuie sur la bibliothèque `libsigrokdecode`. Pour transformer le signal logique brut en information métier exploitable, nous avons superposé deux couches d’analyse (*Stacked Decoders*) comme modélisé sur la **Figure 3** (*Annexe A, p. 14*).

La mise en œuvre pratique dans l’interface graphique de PulseView s’articule en deux étapes d’instrumentation :

1. **Décodeur de niveau 1 (I²C)** : Recherche et assignation du décodeur de protocole I²C dans le catalogue de PulseView (**Figure 13**). Les sondes physiques sont mappées sur les voies correspondantes : canal 0 pour la ligne de données SDA et canal 1 pour la ligne d’horloge SCL. Ce décodeur primaire reconstitue les états de bus (START, STOP, ACK, NACK) et assemble les octets binaires transmis au niveau liaison de données.
2. **Décodeur de niveau 2 (24xx EEPROM)** : Utilisation de la fonctionnalité *Stack Decoder* pour empiler le décodeur applicatif dédié aux mémoires série Microchip 24xx au-dessus du flux I²C (**Figure 14**). Ce module analyse la sémantique mémoire : identification des adresses mémoire sur 16 bits, qualification des commandes (Read / Write) et reconstruction de la charge utile.

L’empilement génère dynamiquement des canaux d’annotations synchronisés sous les formes d’ondes logiques (**Figure 15**, voir *Annexe C, p. 20*). Le panneau de visualisation regroupe ainsi en cohérence temporelle absolue :

- Les signaux numériques bruts (SDA et SCL).
- Les paquets et adresses esclaves I²C décodés au niveau physique.
- Les commandes mémoire et segments de données reconstitués par le décodeur 24xx EEPROM.

8.2. Chronométrie Détaillée des Trames Interceptées

L’analyse temporelle globale de l’enregistrement (**Figure 16**, *Annexe C, p. 21*) met en évidence l’ordonnancement complet des communications sur le bus : une salve initiale d’écriture émise dès le démarrage du microcontrôleur, suivie de salves de lecture régulières espacées d’un intervalle de 2 secondes, conformément aux temporisations définies dans le micrologiciel.

La structure protocolaire de ces deux transactions physiques est représentée sous forme de chronogramme de paquets sur la **Figure 2** (voir *Annexe A, p. 13*). L’examen approfondi révèle deux mécanismes distincts :

8.2.1. Trame d’Écriture Initiale (Phase d’Amorçage)

1. **START** : SDA commute au niveau bas alors que SCL est au niveau haut, réservant le bus.
2. **Sélection du périphérique** : Transmission de l’octet 0xA0 (Adresse 7-bit 0x50 + bit d’écriture W = 0). L’EEPROM acquitte (ACK).
3. **Pointeur d’adresse (16 bits)** :
 - Octet MSB : 0x00, acquitté par l’EEPROM.
 - Octet LSB : 0x10, acquitté par l’EEPROM. Le pointeur interne est verrouillé sur l’adresse mémoire 0x0010.
4. **Flux de données séquentielles** : Transmission consécutive des 15 octets de la clé. L’EEPROM incrémente automatiquement son pointeur après chaque ACK.
5. **STOP** : Libération du bus et déclenchement du cycle interne non-volatile (t_{WR}).

8.2.2. Trame de Lecture Cyclique (Phase Opérationnelle)

1. **Dummy Write** : Émission de 0x50 W suivie de l'adresse 0x0010 afin de caler le pointeur sans transmettre d'octet de donnée.
2. **Repeated START (Sr)** : Le maître génère un nouveau START sans émettre de condition STOP intermédiaire, conservant l'exclusivité du bus.
3. **Sélection en lecture** : Émission de 0x50 avec bit R = 1 (0xA1). L'EEPROM répond par un ACK et prend le contrôle de la ligne SDA.
4. **Émission des données par l'EEPROM** : Le microcontrôleur lit les octets en forçant un ACK sur les 14 premiers octets, puis sanctionne le 15^e octet par un **NACK** pour signifier la fin de la lecture, suivi de la condition STOP.

8.3. Extraction de la Charge Utile & Rétro-Ingénierie ASCII

En exploitant le décodeur applicatif 24xx EEPROM, la charge utile transitant sur le bus physique est automatiquement désérialisée et présentée en clair (Figure 17, Annexe C, p. 22). L'interception physique passive permet ainsi d'extraire la clé d'authentification en intégralité, sans requérir aucune sonde invasive ni altération du matériel ou du microcontrôleur hôte.

La table de correspondance ci-dessous détaille la suite d'octets hexadécimaux bruts capturés et leur traduction immédiate dans le jeu de caractères ASCII :

Index	Hex	Binaire	ASCII	Index	Hex	Binaire	ASCII
0	0x53	01010011	S	8	0x45	01000101	E
1	0x45	01000101	E	9	0x59	01011001	Y
2	0x43	01000011	C	10	0x5F	01011111	—
3	0x52	01010010	R	11	0x31	00110001	1
4	0x45	01000101	E	12	0x32	00110010	2
5	0x54	01010100	T	13	0x33	00110011	3
6	0x5F	01011111	—	14	0x34	00110100	4
7	0x4B	01001011	K				

TABLE 3 – Reconstruction octet par octet de la charge utile interceptée sur le bus I²C.

RÉSULTAT DE L'EXFILTRATION

Clé d'authentification interceptée : SECRET_KEY_1234

9. Matrice des Risques & Analyse d'Impact Industriel

Pour contextualiser la gravité de cette faiblesse dans des déploiements réels, nous appliquons le modèle d'analyse de menaces **STRIDE** (Microsoft) :

10. Contre-Mesures & Architecture Matérielle Sécurisée ("Zero Trust on PCB")

Pour éliminer ce risque dès la phase de conception, l'ingénierie matérielle doit adopter une approche de **défense en profondeur** articulée sur quatre niveaux :

Menace STRIDE	Niveau	Conséquence Opérationnelle dans un Cas Industriel
Spoofing (Usurpation)	CRITIQUE	Récupération de certificats de device ou de clés d'API permettant à un équipement pirate de se faire passer pour un équipement légitime sur le cloud industriel.
Tampering (Altération)	ÉLEVÉ	Injection active sur les lignes I ² C pour écraser des seuils de calibration de capteurs ou modifier les drapeaux d'amorçage (<i>Secure Boot Flags</i>).
Repudiation (Répudiation)	MOYEN	Impossibilité de tracer ou de prouver l'intégrité d'une transaction mémoire non signée en local.
Information Disclosure	CRITIQUE	Constaté sur banc. Exfiltration passive et sans trace de clés de chiffrement de stockage ou de communication réseau (Wi-Fi, LoRaWAN, BLE).
Denial of Service	ÉLEVÉ	Forçage de la ligne SCL ou SDA à la masse (<i>Bus Clamping</i>), neutralisant l'ensemble des périphériques du bus et bloquant le microcontrôleur.
Elevation of Privilege	CRITIQUE	Modification des configurations de privilèges ou contournement de vérification de licence logicielle stockée en mémoire externe.

TABLE 4 – Analyse des menaces STRIDE sur un système embarqué à bus non chiffré.

10.1. Niveau 1 : Remplacement par un Composant Sécurisé (Secure Element)

Dans toute architecture traitant des clés d'authentification ou des certificats de sécurité, l'EEPROM standard doit être remplacée par un coprocesseur cryptographique dédié :

- **Microchip ATECC608A / ATECC608B** : Puce de sécurité I²C intégrant un générateur d'aléa matériel (TRNG), des accélérateurs pour ECDSA (courbe P-256), SHA-256 et AES-128. La puce stocke les clés dans une zone inaccessible par lecture directe.
- **Principe de non-divulgaration de clé** : Le microcontrôleur hôte transmet un défi (*challenge*) sur le bus I²C. Le *Secure Element* calcule la signature cryptographique en interne et renvoie uniquement la preuve de signature. **La clé privée ne transite jamais sur le bus physique.** L'écoute passive des pistes ne capture que des données publiques éphémères non rejouables.
- **Protections physiques internes** : Les puces de type ATECC608 ou NXP EdgeLock SE050 intègrent des boucliers métalliques actifs (*Active Metal Shields*), des capteurs de tension/température et des mécanismes de réinitialisation automatique en cas de tentative de décapage optique ou d'analyse invasive.

10.2. Niveau 2 : Chiffrement Applicatif de la Charge Utile (AEAD)

Si l'utilisation d'une mémoire EEPROM classique demeure indispensable pour des motifs de coût unitaire :

- **Chiffrement au repos et en transit** : Le microcontrôleur doit traiter le bus externe comme un réseau ouvert non sécurisé. Toutes les données doivent être chiffrées à l'aide d'un algorithme de chiffrement symétrique authentifié moderne : **AES-256-GCM** ou **ChaCha20-Poly1305**.
- **Ancrage matériel de la clé racine** : La clé de dérivation ne doit en aucun cas être stockée sur l'EEPROM. Elle doit être dérivée d'une clé maîtresse gravée dans les **fusibles électroniques non réinscriptibles (eFuses)** internes du SoC ESP32-S3, protégée par le module matériel de sécurisation de la Flash (*Flash Encryption*) et du démarrage sécurisé (*Secure Boot*).
- **Résultat** : Même intercepté, le flux de données apparaît sous la forme d'un bruit blanc cryptographique sans valeur pour l'attaquant.

10.3. Niveau 3 : Règles de Routage & Durcissement du Circuit Imprimé

1. **Routage en couches internes (Stripline)** : Ne jamais router les pistes I²C critiques sur les faces externes (*Top* ou *Bottom*) du PCB. Les reléguer sur des couches internes (*Internal Signal Layers*), blindées au-dessus et en-dessous par des plans de masse continus (*GND planes*).
2. **Suppression des points de test (Test Pads)** : Retirer impérativement tous les points de test de fabrication (*ICT Test Pads*) sur les versions de production commerciale, ou les implanter sous des boîtiers BGA inaccessibles sans dessoudage complet.
3. **Encapsulation par résine (Potting Compound)** : Appliquer une résine époxy opaque et hautement polymérisée sur la zone critique du circuit. Toute tentative de grattage mécanique détruit les composants ou arrache les pistes du substrat FR4.

10.4. Niveau 4 : Verrouillage Matériel d'Écriture (Broche WP)

Si la mémoire stocke des données de configuration fixes ou des firmwares secondaires :

- Câbler la broche **WP (Write Protect)** directement au potentiel d'alimentation V_{CC} par une liaison permanente en dur (ou via un pont de soudure masqué).
- L'écriture physique dans les cellules mémoires devient impossible au niveau matériel, immunisant le système contre toute altération malveillante par forçage de bus.

11. Conclusion & Bilan des Compétences

Ce projet de laboratoire a permis de modéliser, reproduire et documenter un vecteur classique d'exposition de données sur les bus inter-composants au niveau circuit imprimé (PCB).

11.1. Compétences Techniques Valorisées

- **Instrumentation & Métrologie Électronique** : Dimensionnement des fréquences d'échantillonnage de Nyquist, configuration de déclencheurs matériels sur signatures d'états, contrôle des continuités et sécurisation du banc de mesure.
- **Rétro-Ingénierie Protocolaire** : Analyse fine des spécifications I²C (open-drain, dimensionnement pull-up, timings t_{WR}), maîtrise des piles de décodeurs Sigrok/PulseView (*Stacked Decoders*) et extraction de données hexadécimales vers ASCII.
- **Posture d'Auditeur en Sécurité Matérielle** : Modélisation de la menace (*Threat Modeling STRIDE*), évaluation standardisée selon la méthodologie CVSS v3.1 et formalisation d'un plan de remédiation industriel cohérent (*Zero Trust on PCB*).

Ce travail constitue l'un de mes premiers bancs d'essai personnels pour monter en compétences pratiques dans le domaine de la **sécurité des systèmes embarqués et de l'audit hardware**. Il concrétise une démarche rigoureuse : caractériser les signaux physiques, analyser les protocoles sans altérer le système hôte, évaluer le risque selon des méthodologies industrielles (CVSS v3.1, STRIDE) et formaliser des contre-mesures concrètes (*Zero Trust on PCB*). Ce socle technique et méthodologique a vocation à être enrichi par de futurs travaux d'analyse (bus SPI, liaisons UART/JTAG, attaques par injection de fautes).

12. Références Techniques & Normatives

1. **NXP Semiconductors** : *UM10204 – I2C-bus specification and user manual*, Rev. 7.0, 2021.
2. **Microchip Technology** : *24AA256/24LC256/24FC256 256K I2C Serial EEPROM Datasheet*, Doc. DS20001203W, 2022.
3. **Espressif Systems** : *ESP32-S3 Series SoC Datasheet & Technical Reference Manual*, Rev. 1.4, 2023.

4. **Projet Sigrok** : *PulseView & libsigrokdecode Protocol Decoders Documentation* (<https://sigrok.org>).
5. **FIRST** : *Common Vulnerability Scoring System (CVSS) v3.1 : Specification Document* (<https://www.first.org/cvss/v3.1/specification-document>).

ANNEXES TECHNIQUES : CAHIER VISUEL & CAPTURES DE BANC

Pour préserver une lecture fluide et synthétique du rapport d'évaluation, l'ensemble des schémas d'architecture, photographies du banc expérimental et captures d'écran de l'analyseur logique (PulseView) sont regroupés dans les présentes annexes techniques. Des renvois cliquables avec indication de page sont intégrés au fil du texte pour faciliter la consultation des illustrations.

Annexe A : Architecture du Système & Modélisation Protocolaire

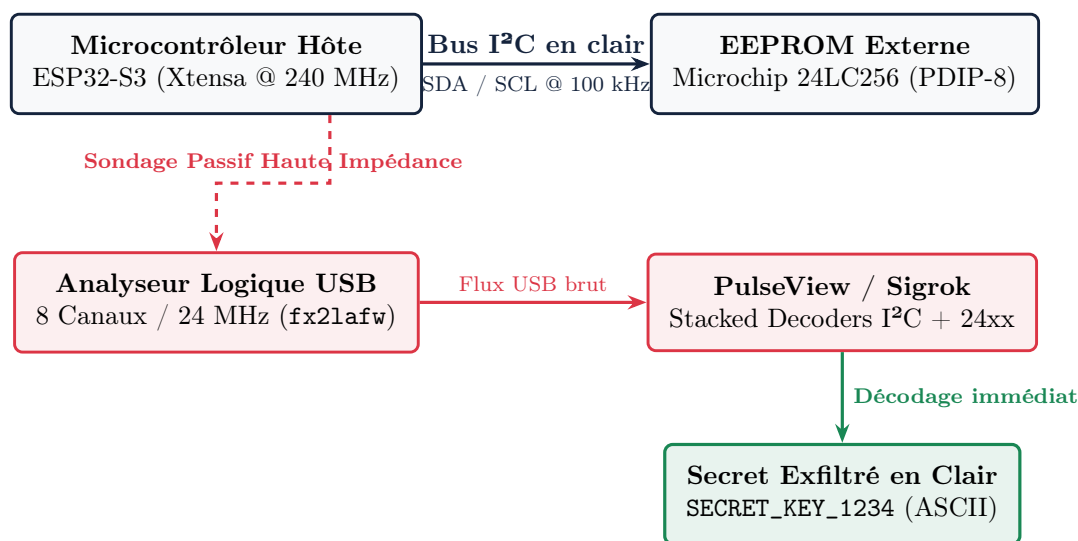
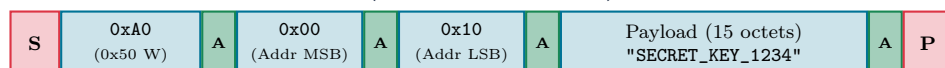
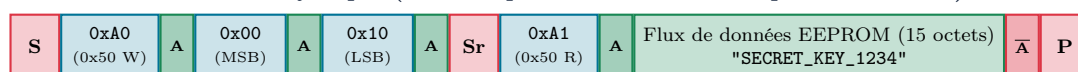


FIGURE 1 – Schéma fonctionnel du vecteur d'écoute passive sur le bus I²C inter-composants.

1. Trame d'Écriture Initiale (Phase d'Amorçage) :



2. Trame de Lecture Cyclique (Phase Opérationnelle avec Repeated START) :



Légende : Maître → Esclave (ESP32-S3) Esclave → Maître (EEPROM 24LC256)
 Signaux de contrôle : S = START · Sr = Repeated START · P = STOP · A = ACK (0) · $\bar{A}$ = NACK (1)

FIGURE 2 – Structure protocolaire détaillée des trames I²C interceptées : transaction d'écriture initiale et transaction de lecture aléatoire avec Repeated START (*Sr*).

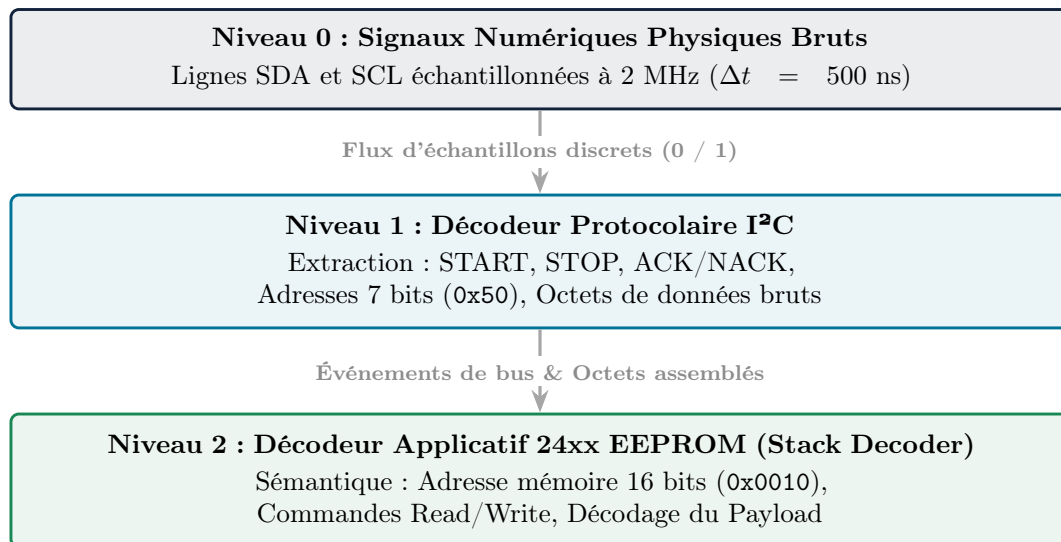


FIGURE 3 – Chaîne de décodage protocolaire multiniveau dans Sigrok / PulseView.

Annexe B : Galerie Photographique du Banc de Test Matériel



FIGURE 4 – Composant physique testé : boîtier PDIP-8 (24LC256-I/P YU8 2601).

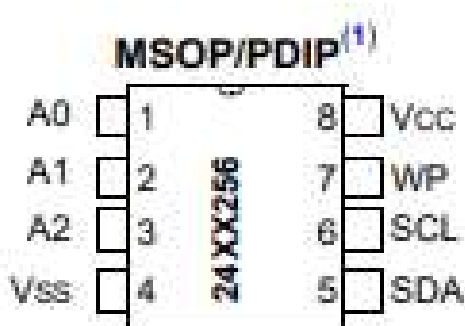


FIGURE 5 – Brochage constructeur (*Datasheet Microchip DS20001203*).

Absolute Maximum Ratings ^(†)	
Vcc.....	6.5V
All inputs and outputs w.r.t. Vss	-0.6V to Vcc +1.0V
Storage temperature	-65°C to +150°C
Ambient temperature with power applied.....	-40°C to +125°C
ESD protection on all pins	≥4 kV

† NOTICE: Stresses above those listed under "Absolute Maximum Ratings" may cause permanent damage to the device. This is a stress rating only and functional operation of the device at these or any other conditions above those indicated in the operational listings of this specification is not implied. Exposure to Absolute Maximum Rating conditions for extended periods may affect device reliability.

FIGURE 6 – Spécifications limites d’exploitation et protection ESD (≥ 4 kV) issues de la documentation Microchip.

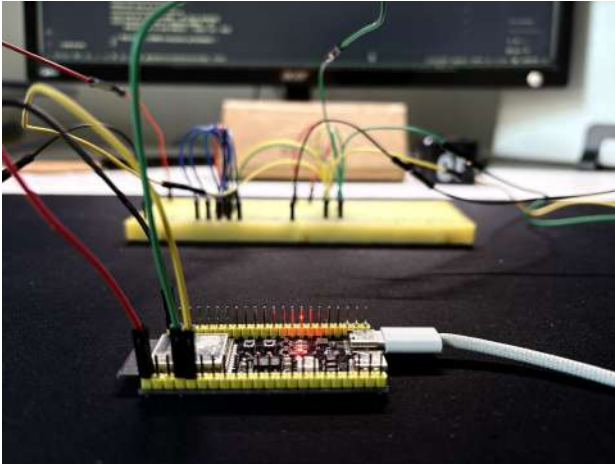


FIGURE 7 – Microcontrôleur ESP32-S3 et liaisons I²C vers les broches GPIO 4 (SDA) et GPIO 5 (SCL).

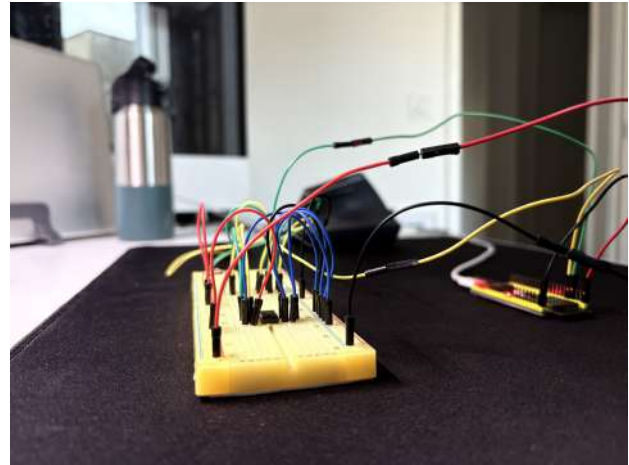


FIGURE 8 – Mémoire EEPROM 24LC256 sur plaque d'essai avec les lignes de tirage et de masse.

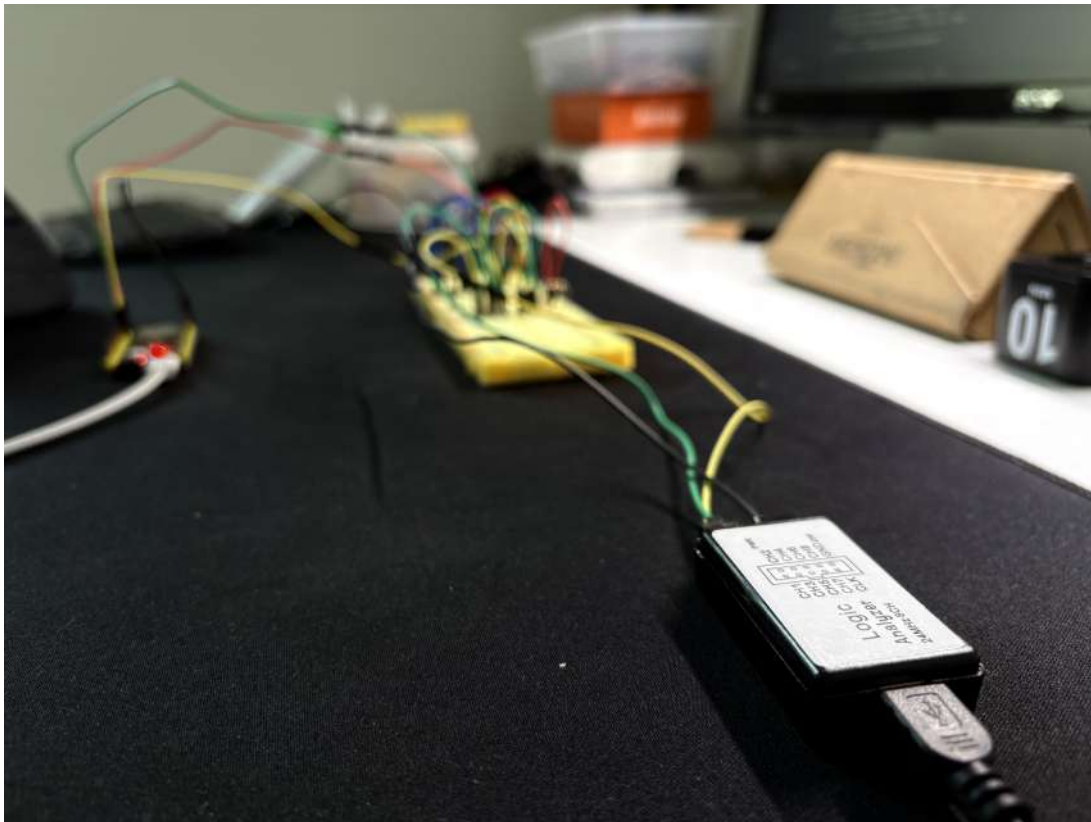


FIGURE 9 – Banc expérimental instrumenté : analyseur logique 8 canaux connecté en dérivation sur les lignes SDA, SCL et GND.

Annexe C : Captures d'Instrumentation & Preuves d'Exfiltration (PulseView)



FIGURE 10 – Détection et sélection du pilote open-source fx2lafw dans PulseView.

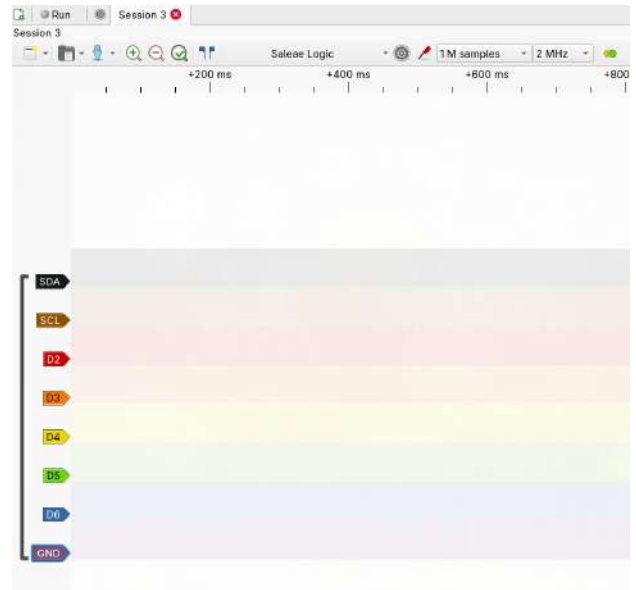


FIGURE 11 – Configuration des canaux (SDA, SCL, GND) et paramétrage à 2 MHz / 1 MSamples.

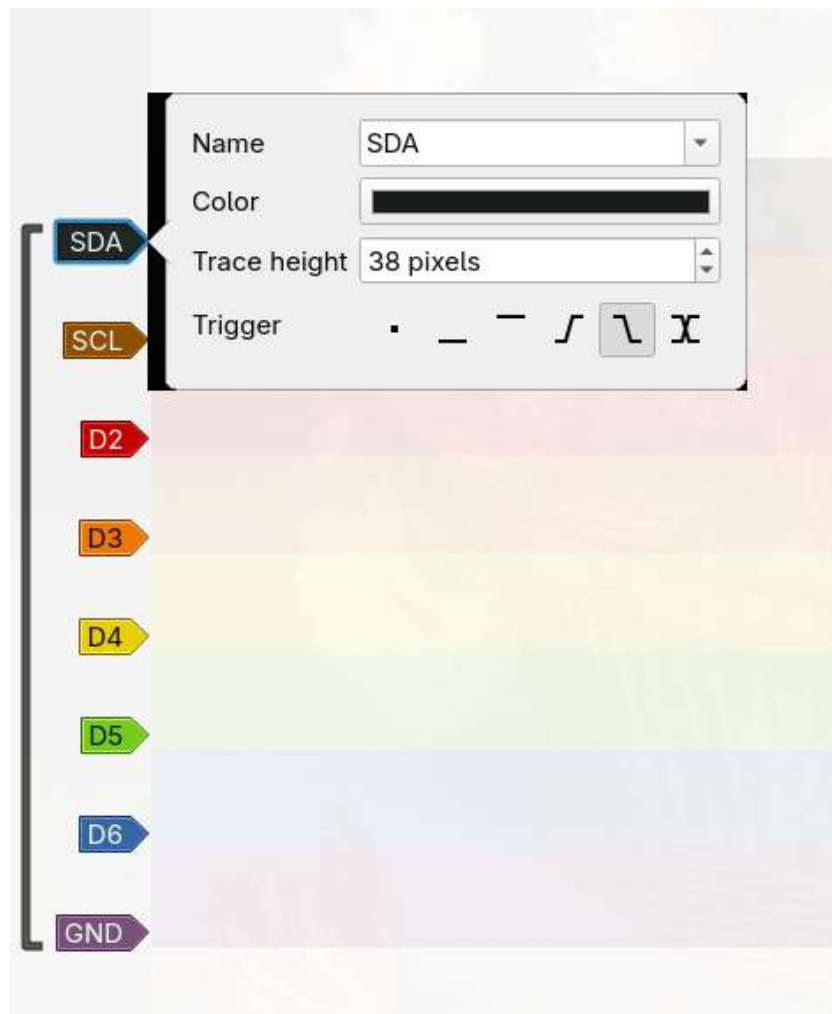


FIGURE 12 – Configuration du déclencheur matériel (*Trigger*) sur front descendant sur SDA (signature de la condition START).

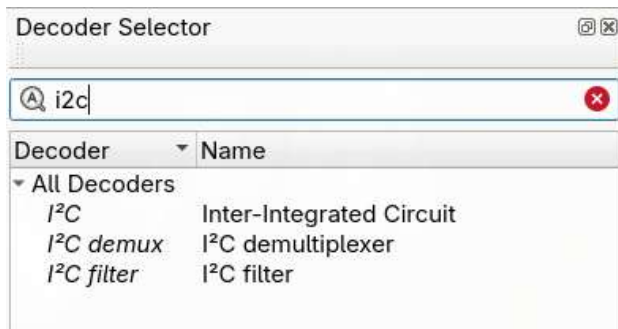


FIGURE 13 – Sélection et intégration du décodeur de protocole I²C de base.

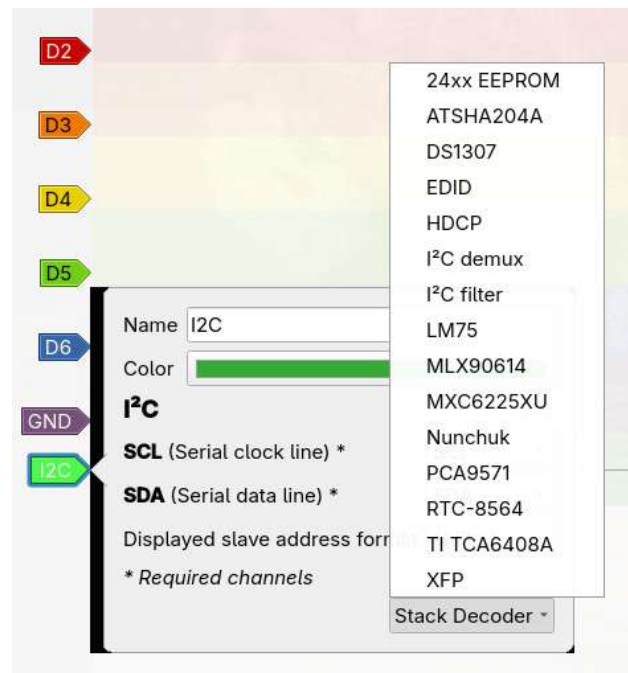
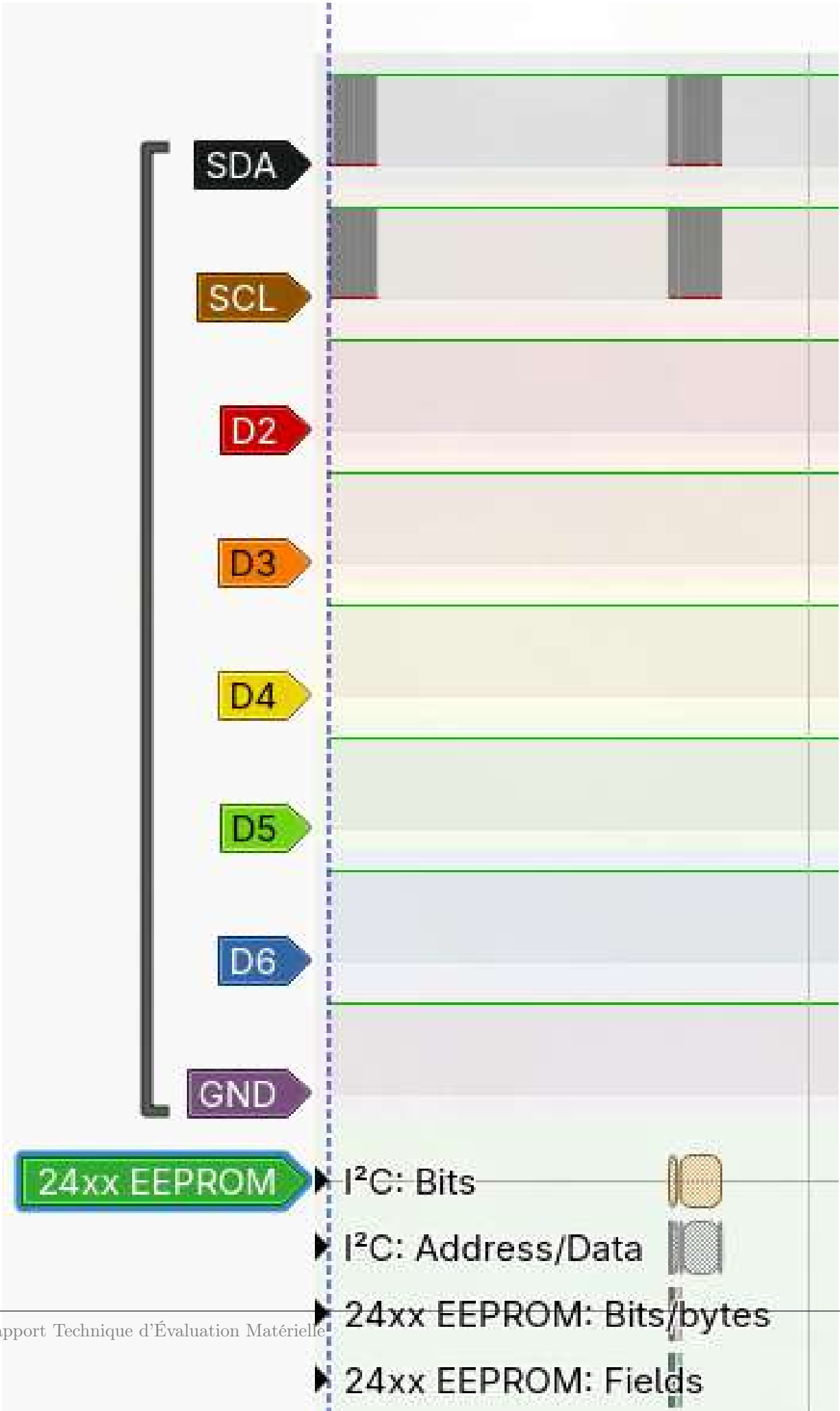
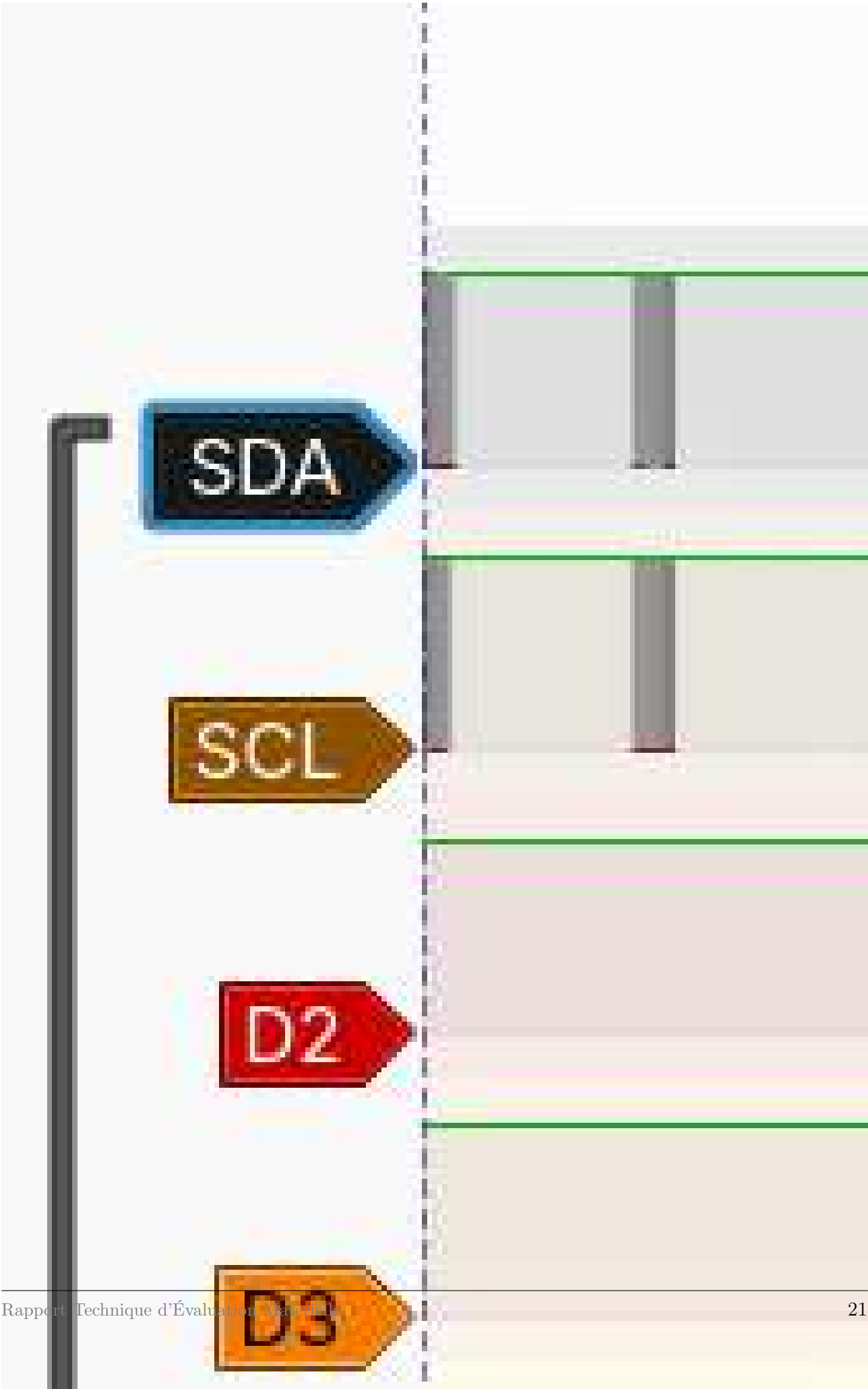


FIGURE 14 – Empilement du décodeur applicatif spécialisé pour mémoire EEPROM 24xx.





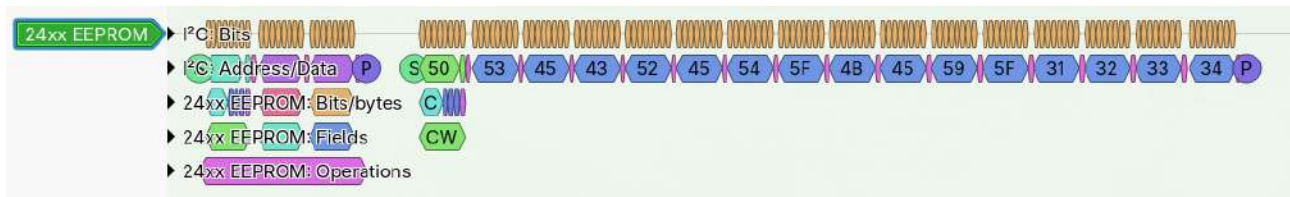


FIGURE 17 – Preuve d’exfiltration matérielle : décodage applicatif direct affichant la charge utile interceptée "SECRET_KEY_1234".